

1. Opis działania firmy, struktura i organizacja pracy

SecureNow Sp. z o.o. prowadzi działalność w sektorze zaawansowanych usług informatycznych dla klientów biznesowych i instytucjonalnych (model B2B i B2G). Przedsiębiorstwo zajmuje się projektowaniem, utrzymaniem i rozwojem systemów teleinformatycznych, cyberbezpieczeństwem oraz zarządzaniem środowiskami chmurowymi. Ze względu na charakter świadczonych usług, firma na bieżąco dostosowuje swoje procesy do wymogów Krajowego Systemu Cyberbezpieczeństwa (KSC) oraz dyrektywy NIS2, opierając się na szacowaniu ryzyka i odpowiednim zabezpieczaniu aktywów informacyjnych.

Struktura Organizacyjna

Struktura organizacyjna została zoptymalizowana pod kątem ciągłości świadczenia usług i bezpieczeństwa. Najwyższy nadzór sprawuje Zarząd, któremu bezpośrednio podlegają kluczowe piony i ich dyrektorzy:

- **Pion operacyjny (COO):** zarządza wdrożeniami, utrzymaniem systemów oraz pierwszą linią wsparcia (Service Desk).
- **Pion technologiczny (CTO):** skupia zespoły programistyczne, administratorów infrastruktury oraz inżynierów DevOps.
- **Pion bezpieczeństwa (CISO):** Pełnomocnik ds. Cyberbezpieczeństwa kieruje pracami Security Operations Center (SOC) i współpracuje z Inspektorem Ochrony Danych (IOD).
- **Działy wspierające:** sprzedaży oraz administracyjno-finansowy.

Model Operacyjny i Zatrudnienie

Działalność operacyjna firmy prowadzona jest w modelu rozproszonym. **Siedziba główna**, objęta ścisłą kontrolą fizycznego dostępu, stanowi centrum zarządcze. Środowiska produkcyjne oraz kopie zapasowe utrzymywane są w certyfikowanych centrach przetwarzania danych (Tier III/IV) zlokalizowanych na terenie EOG. Zespoły techniczne pracują w modelu zdalnym i hybrydowym, korzystając z zabezpieczonych kanałów VPN, wieloskładnikowego uwierzytelniania (MFA) oraz urządzeń centralnie nadzorowanych (MDM, EDR).

Organizacja zatrudnia około 35 specjalistów. Ze względów bezpieczeństwa formy współpracy zostały zróżnicowane w zależności od obszaru:

Obszar / Stanowiska	Model zatrudnienia	Uzasadnienie
Role zarządcze i nadzorcze (CISO, liderzy SOC, IOD, administratorzy infrastruktury krytycznej)	Umowa o pracę	Ułatwia egzekwowanie rygorystycznych procedur bezpieczeństwa.
Piony technologiczne i operacyjne (programiści, inżynierowie chmurowi, architekci IT)	Kontrakty B2B	Elastyczność operacyjna przy zachowaniu rygorystycznych zasad ochrony danych.
Pierwsza linia wsparcia (Service Desk)	Umowy cywilnoprawne	Dopuszczalne rozwiązanie wspierające ciągłość pracy w systemie zmianowym.

Segmenty Klientów

Klienci SecureNow dzielą się na trzy główne grupy:

1. **Duże przedsiębiorstwa i instytucje publiczne:** potężne bazy danych obywateli i pracowników; ewentualny incydent mógłby sparaliżować usługi kluczowe (w rozumieniu KSC).
2. **Sektor MŚP (placówki medyczne, e-commerce):** utrzymanie infrastruktury przetwarzającej dane wrażliwe i medyczne podlegające szczególnej ochronie RODO.
3. **Kooperanci w łańcuchu dostaw:** m.in. dostawcy usług chmurowych, co wymaga ciągłego audytowania poziomu bezpieczeństwa wymiany informacji.

2. Polityka Bezpieczeństwa Informacji

Polityka bezpieczeństwa informacji SecureNow Sp. z o.o. ma na celu zagwarantowanie **poufności, integralności i dostępności** danych przetwarzanych w procesach biznesowych firmy. Jest ona ściśle powiązana z rolą spółki jako dostawcy usług ICT, dostosowując wymagania operacyjne do reżimów prawnych KSC, NIS2 oraz RODO.

Przepisy polityki mają charakter uniwersalny i wiążą wszystkich pracowników, zarząd, współpracowników zewnętrznych oraz partnerów mających dostęp do zasobów firmy.

Kontrola Dostępu i Środowisko Pracy

- **Kategoryzacja informacji:** Dane dzielą się na publiczne, wewnętrzne, poufne i szczególnie chronione.
- **Minimalne uprawnienia (Least Privilege):** Dostęp nadawany jest wyłącznie w zakresie niezbędnym do wykonania zadań, zawsze po zatwierdzeniu przez przełożonego.
- **Zasady uwierzytelniania:** Obligatoryjne stosowanie silnych haseł, MFA oraz nadzorowanie kont uprzywilejowanych.
- **Praca zdalna:** Zabronione jest wykorzystywanie urządzeń prywatnych (BYOD) do celów służbowych. Wszystkie służbowe urządzenia końcowe podlegają centralnemu zarządzaniu i ochronie antymalware.

Ciągłość Działania i Ochrona Danych

Ciągłość świadczenia usług zabezpieczana jest poprzez wdrożone plany odtwarzania po awarii (**DRP**) i ciągłości działania (**BCP**). Kluczowym środkiem obronnym przed awariami i atakami ransomware jest harmonogramowe tworzenie szyfrowanych, odizolowanych logicznie i regularnie testowanych **kopii zapasowych**.

Świadomość i Reagowanie na Incydenty

- **Szkolenia:** Personel jest regularnie szkolony w zakresie zagrożeń cybernetycznych i ochrony danych osobowych.
- **Raportowanie:** Wszelkie anomalie (niedostępność usług, wyciek danych, phishing) muszą być natychmiast zgłaszane do CISO i SOC.
- **CSIRT:** Poważne zdarzenia rzutujące na infrastrukturę klientów kluczowych podlegają ustawowemu raportowaniu do właściwego zespołu CSIRT.
- **Zarządzanie ryzykiem:** Fundamentem procesów jest coroczna analiza ryzyka aktywów informacyjnych. Wszelkie celowe naruszenia polityki przez personel skutkują pociągnięciem do odpowiedzialności dyscyplinarnej lub prawnej.

Niniejsza sekcja ma na celu opisanie środków bezpieczeństwa chroniących zasoby firmy, jej klientów oraz przetwarzane dane wrażliwe. Celem wdrożonych zasad jest zapobieganie nieautoryzowanemu dostępowi, modyfikacji, zniszczeniu lub wyciekowi informacji. Każda procedura posiada własną nazwę, identyfikuje ryzyko, określa zakres obowiązywania oraz definiuje konkretne kroki postępowania.

Procedura 1: Postępowanie w przypadku utraty urządzenia służbowego (endpoint)

- **Tytuł procedury:** Procedura postępowania w przypadku utraty urządzenia służbowego

- **Cel:** Celem tej procedury jest zabezpieczenie poufnych danych klientów oraz innych wrażliwych informacji firmowych przed wyciekiem w przypadku, gdyby niepożądana osoba weszła w posiadanie sprzętu.
- **Zakres:** Procedura dotyczy każdego pracownika mającego dostęp do jakiegokolwiek urządzenia firmowego (laptopów, telefonów, tabletów).
- **Kroki postępowania (Zasady):**
 1. Natychmiast po zgubieniu sprzętu pracownik zobowiązany jest zgłosić sytuację do CISO. Należy wyjaśnić, kiedy doszło do zdarzenia, podać szacowane miejsce, rodzaj urządzenia i przypisanego do niego użytkownika.
 2. CISO przekazuje sprawę administratorom, którzy natychmiast odcinają urządzenie od zasobów firmy. Polega to na: zablokowaniu dostępu przez VPN, wylogowaniu użytkownika ze wszystkich sesji, sprawdzeniu logów pod kątem anomalii z IP tego urządzenia oraz próbie jego namierzenia. Następnie administrator wysyła komendę zdalnego wymazania danych (remote wipe).
 3. Jeśli zachodzi podejrzenie, że osoba niepowołana uzyskała dostęp do danych na endpoincie, incydent należy zgłosić na policję, a CISO rozpatruje konieczność zgłoszenia naruszenia do UODO.

Procedura 2: Procedura w przypadku zwolnienia (offboarding)

- **Tytuł procedury:** Procedura odbierania uprawnień i sprzętu w przypadku zakończenia współpracy
- **Cel:** Celem procedury jest zagwarantowanie, że pracownik lub kontraktor po ustaniu stosunku pracy nie będzie w stanie zalogować się do systemów firmowych, skopiować danych klientów ani wyrządzić szkód w infrastrukturze.
- **Zakres:** Procedura dotyczy każdego pracownika oraz współpracownika B2B, który kończy współpracę z firmą SecureNow.
- **Kroki postępowania (Zasady):**
 1. Bezpośrednio przed wręczeniem wypowiedzenia (lub w momencie wygaśnięcia umowy), dział HR/przełożony informuje administratorów IT o konieczności rozpoczęcia procedury offboardingu.
 2. Dział IT natychmiastowo blokuje (dezaktywuje) wszystkie konta dostępowe użytkownika, odcina dostęp do firmowego VPN oraz wymusza wylogowanie z aktywnych sesji pocztowych.
 3. Pracownik jest zobowiązany do zwrotu całego powierzonego sprzętu (laptop, telefon, klucze sprzętowe) do działu IT w ostatnim dniu pracy, co zostaje potwierdzone podpisanym protokołem zdawczo-odbiorczym.
 4. Zwrócone urządzenia końcowe, przed przekazaniem kolejnym pracownikom, zostają poddane całkowitemu resetowi (secure wipe) przez administratorów, aby usunąć wszelkie dane lokalne.

Procedura 3: Zasada nadawania uprawnień nowym pracownikom

- **Tytuł procedury:** Procedura nadawania uprawnień w systemach informatycznych dla nowych pracowników
- **Cel:** Celem procedury jest nadanie pracownikowi uprawnień niezbędnych do wykonywania jego obowiązków służbowych, przy jednoczesnym rygorystycznym zachowaniu zasady minimalnych uprawnień (*Least Privilege*).

- **Zakres:** : Procedura dotyczy każdego pracownika oraz współpracownika B2B, który rozpoczyna współpracę z firmą SecureNow.
- **Kroki postępowania (Zasady):**
 1. Przed rozpoczęciem pracy, dział HR we współpracy z bezpośrednim przełożonym pracownika generuje wniosek dostępowy, określający stanowisko i zakres obowiązków nowej osoby.
 2. Na podstawie wniosku administrator IT przypisuje konto użytkownika do odpowiednich grup ról w usłudze katalogowej (np. Active Directory). Każda grupa posiada skonfigurowane najniższe możliwe uprawnienia, które umożliwiają bezproblemową pracę.
 3. Pracownik otrzymuje jednorazowe hasło startowe. Przy pierwszym logowaniu system wymusza na nim zmianę hasła na własne (zgodne z polityką bezpieczeństwa) oraz obowiązkową konfigurację logowania dwuetapowego (MFA) w aplikacji mobilnej.

Procedura 4: Zasada bezpiecznej pracy w miejscach publicznych

- **Tytuł procedury:** Procedura bezpiecznej pracy na urządzeniach firmowych w przestrzeniach publicznych.
- **Cel:** Celem tej procedury jest wdrożenie bezpiecznych zasad korzystania z urządzeń firmowych poza biurem i domem, aby uniknąć fizycznych naruszeń bezpieczeństwa, wycieku danych (np. podglądania ekranu) lub przechwycenia ruchu sieciowego.
- **Zakres:** Procedura dotyczy każdego pracownika i współpracownika, który korzysta z urządzeń służbowych w miejscach publicznych (pociągi, lotniska, kawiarnie, hotele).
- **Kroki postępowania (Zasady):**
 1. Użytkownik ma bezwzględny zakaz logowania się do otwartych, publicznych sieci Wi-Fi bez użycia firmowego tunelu VPN. Zaleca się korzystanie z własnego hotspota utworzonego na telefonie służbowym.
 2. Podczas pracy w miejscach, w których obecne są osoby trzecie, pracownik ma obowiązek stosować na ekranie laptopa nałożone szkło/folię prywatyzującą.
 3. Pracownik nie może pozostawiać urządzenia służbowego bez nadzoru. W przypadku konieczności chwilowego oddalenia się od sprzętu, ekran musi zostać zablokowany (skrót klawiszowy np. Win+L).

Procedury dotyczące ciągłości działania

Procedura 1: Postępowanie i utrzymanie ciągłości działania w przypadku kompromitacji serwera

- **Tytuł procedury:** Procedura reagowania na incydent naruszenia serwera i przełączania awaryjnego (Failover).
- **Cel:** Zapewnienie nieprzerwanego dostępu do usług w momencie cyberataku na infrastrukturę (High Availability), powstrzymanie rozprzestrzeniania się zagrożenia oraz zabezpieczenie materiału dowodowego do analizy.
- **Zakres:** Wszystkie serwery produkcyjne SecureNow. Za realizację odpowiadają: CISO, zespół DFIR, analitycy SOC oraz Administratorzy Infrastruktury.
- **Kroki postępowania (Zasady):**
 1. **Izolacja i Przełączenie (Failover):** Natychmiast po potwierdzeniu naruszenia, administratorzy izolują zainfekowany serwer od sieci wewnętrznej i internetu (zapobieganie ruchom bocznym/lateral movement). Cały ruch sieciowy zostaje

- automatycznie lub ręcznie przekierowany na serwer zapasowy (klaster niezapasowy/CDN), aby utrzymać ciągłość usług dla klientów.
2. **Zabezpieczenie i Analiza (DFIR):** Zespół SOC oraz specjaliści DFIR przystępują do zabezpieczenia dowodów cyfrowych (zrzuty pamięci RAM, logi) na odizolowanym serwerze. Trwa śledztwo mające ustalić wektor ataku oraz zakres ewentualnej eksfiltracji (kradzieży) danych.
 3. **Scenariusz A (Brak wycieku):** Jeśli atakujący nie uzyskał dostępu do poufnych informacji, incydent jest zamykany. Zespół sporządza raport *Lessons Learned*, aktualizuje sygnatury i reguły w systemach EDR/Firewall oraz organizuje wewnętrzne szkolenie dla personelu podnoszące świadomość bezpieczeństwa.
 4. **Scenariusz B (Wyciek danych):** Jeśli śledztwo wykaże utratę lub kompromitację danych, CISO zgłasza incydent do UODO (Urząd Ochrony Danych Osobowych) w ciągu 72 godzin, powiadamia właściwy zespół CSIRT (wymóg KSC), a sprawa zostaje przekazana do CBZC (Centralnego Biura Zwalczania Cyberprzestępczości). Środowisko jest odtwarzane od zera z ostatniej czystej kopii zapasowej.

Procedura 2: Postępowanie i utrzymanie ciągłości działania w przypadku całkowitej utraty połączenia z siecią (Blackout) głównym centrum danych

- **Tytuł procedury:** Procedura utrzymania ciągłości działania w przypadku całkowitej utraty połączenia z siecią w głównym centrum
- **Cel:** Zapewnienie dostępności kluczowych zasobów firmy, zminimalizowanie czasu przestoju usług klienckich oraz utrzymanie ciągłości biznesowej w warunkach infrastrukturalnego stanu awaryjnego.
- **Zakres:** Infrastruktura głównego Data Center, zapasowe łącza dostawców Internetu (ISP), awaryjne systemy zasilania (UPS, agregaty) oraz zespół administratorów IT i Service Desk.
- **Kroki postępowania (Zasady):**
 1. W momencie wystąpienia awarii systemy automatycznie przełączają się na zasilanie awaryjne (akumulatory UPS podtrzymujące sprzęt do czasu startu agregatów spalinowych) oraz na zapasowe, niezależne łącze internetowe od innego dostawcy (tzw. redundancja ISP).
 2. Jeśli awaria ma charakter rozległy, a podstawowe środowisko pozostaje niedostępne przez ponad 15 minut, administratorzy podejmują decyzję o uruchomieniu procedury Disaster Recovery (DRP). Cały ruch zostaje przełączony na zapasowe centrum danych zlokalizowane w innym mieście.
 3. W trakcie przełączania środowisk, Service Desk natychmiast wysyła komunikaty do klientów i pracowników za pomocą alternatywnych, bezpiecznych kanałów (np. awaryjna bramka SMS), informując o statusie prac.
 4. Po całkowitym usunięciu awarii w głównej serwerowni, powrót infrastruktury do stanu pierwotnego (tzw. Failback) przeprowadzany jest wyłącznie w nocnych oknach serwisowych, aby uniknąć ponownego odcinania użytkowników.

W firmie SecureNow Sp. z o.o. proces szacowania ryzyka informatycznego opiera się na wytycznych amerykańskiego standardu **NIST SP 800-30**. Metodologia ta polega na jakościowej ocenie dwóch kluczowych czynników:

- **Prawdopodobieństwo wystąpienia zdarzenia:** określa, jak duże są szanse na to, że dane zagrożenie wystąpi i wykorzysta lukę w systemie
- **Wpływu na organizację:** określa potencjalne starty finansowe i operacyjne dla firmy w przypadku materializacji zagrożenia

Oba parametry oceniane są na zasadzie skali: Niskie, Średnie, Wysokie. Wynik końcowy wyznaczany jest na podstawie matrycy ryzyka NIST:

Prawdopodobieństwo \ Skutek	Skutek: Niski	Skutek: Średni	Skutek: Wysoki
Wysokie	Ryzyko: Średnie	Ryzyko: Wysokie	Ryzyko: Bardzo Wysokie
Średnie	Ryzyko: Niskie	Ryzyko: Średnie	Ryzyko: Wysokie
Niskie	Ryzyko: Bardzo Niskie	Ryzyko: Niskie	Ryzyko: Średnie

Zasady postępowania z ryzykiem:

- Ryzyko Niskie i Bardzo Niskie jest akceptowalne
- Ryzyko Średnie wymaga monitorowania i planowania zabezpieczeń w przyszłości
- Ryzyko Wysokie i Bardzo Wysokie jest nieakceptowalne i wymaga natychmiastowego wdrożenia procedur mitygujących

Przykład szacowania ryzyka:

Aktywo: Laptop pracownika zawierający lokalną kopie danych kontaktowych klientów B2B

Zagrożenie: Kradzież lub zgubienie urządzenia w miejscu publicznym (np. w pociągu czy metrze)

Podatność: Brak procedur zarządzania sprzętem, brak włączonego szyfrowania dysku.

Krok 1: Ocena ryzyka pierwotnego (przed wdrożeniem procedury):

- **Prawdopodobieństwo:** Średnie (zgubienie sprzętu mobilnego zdarza się raczej stosunkowo regularnie)
- **Skutek:** Wysoki (osoba nieuprawniona uzyskuje dostęp do wszystkich danych klientów, co grozi karami RODO i utratą zaufania)
- **Poziom ryzyka pierwotnego:** Wysokie (Średnie x Wysokie). Sytuacja wymaga natychmiastowej reakcji

Krok 2: Wdrożenie mechanizmów kontrolnych (Mitygacja):

Firma wdraża przygotowaną Procedurę 1 (Postępowanie w przypadku utraty urządzenia służbowego), która wymusza obowiązkowe szyfrowanie dysków (np. BitLocker) oraz możliwość zdalnego wymazania zawartości (Remote Wipe) przez administratora IT natychmiast po zgłoszeniu.

Krok 3: Ocena ryzyka szczątkowego (po wdrożeniu procedury):

- Prawdopodobieństwo: Średnie (urządzenia dalej będą gubione, nie da się tego wyeliminować, ponieważ zależy to od ludzkiej nieuwagi)
- Skutek: Niski (dzięki mocnemu szyfrowaniu i zdalnemu czyszczeniu, znalazca laptopa widzi tylko niezrozumiały ciąg znaków, dane klientów są w 100% bezpieczne)
- Poziom ryzyka szczątkowego: Niskie (Średnie x Niski)

Wniosek: Dzięki wdrożeniu Procedury 1, ryzyko spadło z nieakceptowalnego (Wysokie) do poziomu akceptowalnego (Niskie). Działania zabezpieczające zakończyły się sukcesem.